

Meridian Coffee Roasters
Information Security Policy

Version 3.1, approved by the board on 20 January 2025.

Applies to all employees, contractors and third parties with access to Meridian systems or data.

1. Scope and Ownership

The Head of Engineering is the accountable owner of this policy. It is reviewed annually and after any Severity 1 security incident.

This policy governs information security. It sits alongside, and does not replace, the acceptable-use provisions in the Employee Handbook. Where the two appear to conflict, this policy takes precedence for anything touching production systems or customer data.

2. Data Classification

Meridian classifies data into four levels.

- Public Published material. No restriction.
- Internal Default for business data. Employees and contractors only.
- Confidential Customer records, financials before publication, contracts.
 Access on a need-to-know basis, logged.
- Restricted Authentication secrets, encryption keys, payment tokens.
 Access requires named approval and is reviewed monthly.

Data must be classified at creation. Unclassified data is treated as Confidential until classified, not as Internal.

3. Access Control

Access follows least privilege and is granted by role, never to an individual directly. Role membership is reviewed quarterly by the system owner.

Multi-factor authentication is mandatory for all systems holding Internal data or above. For production systems the second factor must be a hardware security key; time-based codes and SMS are not accepted.

Shared accounts are prohibited. Where a vendor system cannot support individual accounts, the exception must be recorded in the risk register with a named owner and a review date.

Access is revoked within four hours of an employee's departure, and immediately where the departure is involuntary. This is faster than the general system access revocation described in the Employee Handbook, which applies to non-production systems.

Dormant access is removed automatically after 60 days without use.

4. Passwords and Secrets

All work credentials live in the company password manager. Reuse of a work password on any personal service is prohibited.

Application secrets are held in the secret manager and injected at runtime. Secrets must never be committed to a repository, written to application logs, included in an error report, or pasted into a chat or ticket.

Any secret exposed by any of those routes is treated as compromised and rotated the same working day, whether or not there is evidence of misuse.

5. Endpoint Security

Company laptops run full-disk encryption and a managed endpoint agent. Personal devices may access company email and chat, but may not hold Confidential data and may not access production systems.

Operating system and browser updates must be applied within 14 days of release, and within 48 hours for a vulnerability rated critical.

Devices lock automatically after 5 minutes of inactivity.

A lost or stolen device must be reported within 24 hours so it can be remotely wiped.

6. Vendor and Third-Party Risk

Any vendor processing Confidential or Restricted data requires a security review before contract signature. The review covers data location, subprocessors, breach notification terms and deletion on termination.

Vendors handling Restricted data must notify Meridian of a breach within 24 hours. Vendors handling Confidential data must notify within 72 hours.

The vendor register is reviewed twice a year. A vendor that has not been used for twelve months has its access terminated.

7. Secure Development

All code changes require review by someone other than the author before merge. Changes touching authentication, payments or customer data require review by two people, at least one of whom is on the platform team.

Dependencies are scanned on every pipeline run. A critical vulnerability blocks the pipeline; a high vulnerability opens a ticket with a 14-day remediation target.

Production data may never be copied into development. Staging holds anonymised data only and is refreshed weekly.

Penetration testing is commissioned annually from an external firm. The most recent test was completed in November 2024 and produced four findings: one medium and three low. All four were remediated by 20 December 2024.

8. Logging and Monitoring

Authentication events, access to Confidential data, and all administrative actions are logged centrally. Logs are immutable and retained for 400 days.

Logs must not contain secrets, full payment details, or customer passwords. Where a log would otherwise capture such a field, it is redacted at source rather than filtered later.

9. Incident Response

A security incident is any event that compromises, or may compromise, the confidentiality, integrity or availability of Meridian data.

Anyone who suspects an incident reports it immediately to the platform on-call. There is no penalty for reporting something that turns out to be benign, and staff are explicitly encouraged to report early rather than investigate first.

Severity 1 security incidents require notification to the Head of Engineering and the CEO within one hour of confirmation.

Where personal data is involved, the Head of Engineering determines the notification obligation. Regulatory notification deadlines are assumed to be 72 hours from confirmation unless legal advice says otherwise.

Every security incident receives a written postmortem within five working days, following the same blameless format used for availability incidents.

10. Training and Exceptions

All staff complete security awareness training on joining and annually thereafter. Engineers complete an additional secure-development module.

Any exception to this policy requires written approval from the Head of Engineering, a documented compensating control, and an expiry date no more than six months out. Exceptions without an expiry date are not granted.